

Coordinated Vulnerability Disclosure Policy

Grounded in: Modeled on Medtronic's public product-security program

Basis: §524B(b)(1); FDA postmarket guidance; AAMI TIR97.

Basis	Modeled on Medtronic's publicly documented coordinated-disclosure / product-security program
Regulatory	§524B(b)(1); FDA Postmarket Cybersecurity guidance; AAMI TIR97
Note	Illustrative structure; not Medtronic's verbatim policy.

1. Scope & contact

Marketed products and connected services. Public security page with a reporting form and a published PGP key; security@ intake.

2. Reporting & safe harbor

Good-faith research welcomed; acknowledgment within a stated window; no legal action for testing within the policy.

3. Coordination & CVEs

- Triage and validate reports; assign/track CVEs (CNA or via a CNA).
- Coordinate with CISA / ICS-CERT; publish security bulletins/advisories.
- Credit researchers per coordinated-disclosure norms.

4. Timelines & remediation

Severity	Target remediation	Interim
Critical	Expedited (e.g., ≤ 30 days)	Compensating controls / advisory
High	Defined window	Mitigation guidance
Medium/Low	Scheduled release	Tracked to closure

5. Regulator reporting

Assess 21 CFR 806 correction/removal and 803 MDR triggers; align to FDA postmarket cybersecurity guidance.

Sources (public)

- Medtronic — publicly documented Product Security / coordinated vulnerability disclosure (PSIRT) program.
- FDA — Postmarket Management of Cybersecurity in Medical Devices (2016); §524B(b)(1).

- AAMI TIR97 (postmarket security); CISA ICS medical advisory coordination.